PQC Scanner Full Test Plan

Ordered end-to-end test checklist

1. Environment / startup
- Docker/local stack starts
- Cloud Run API/worker/beat healthy
- Postgres/Redis reachable
- UI loads

2. Automated regression suite
- Run backend pytest suites for compliance gate, remediations, RBAC/audit, multi-tenancy, GitHub App bridge, compliance report, drift/notifications, drift response, and hosted JWT auth

3. Auth / login
- Auth0 login works
- Logout works
- /auth/config is correct
- /auth/context returns authenticated user after login
- Role/org claims are read from JWT
- Unauthenticated access is blocked where expected

4. RBAC
- Viewer blocked from write actions
- Operator allowed for normal remediation flow
- Admin allowed for sensitive actions
- Deny events appear in audit log

5. Multi-tenancy / org isolation
- Org A only sees org A data
- Org B only sees org B data
- Same repo name / asset key can exist across orgs
- JWT org claim scopes requests correctly

6. Vault / credentials
- Credentials list works
- GitHub App credential resolves correctly
- Secrets are not exposed in responses
- Temporary/manual creds are not required for normal GitHub App flow

7. GitHub App integration
- Installation sync works
- Repository sync works
- Target repo appears in /repositories
- Repo token minting works for that repo

8. Scan lifecycle

- Create scan
- Job starts in background
- Progress updates
- Scan reaches completed
- Results persist after refresh/reload

9. Asset inventory / asset views
- Assets list loads
- Asset detail loads
- Metadata/tags update works
- Asset history works

10. Correlation
- Correlate assets to repos
- Linked repo appears on asset record
- Linked asset appears in repo-related views

11. Compliance gate
- Repo with linked critical finding returns FAIL
- Clean/no-linked-risk case returns expected pass behavior

12. Remediation suggestion
- Suggest remediation from repo + asset
- Original content loads from GitHub
- Suggested content/diff created
- No wrapper-marker corruption in new suggestions

13. Remediation approval / rejection
- Approve works
- Reject works
- Status transitions correct
- Audit log records action

14. Validation sandbox
- Validate remediation
- Terraform validation passes for valid fix
- Failed validation stores exit code/stdout/stderr
- PR creation blocked when latest validation failed

15. PR creation
- Create PR from validated remediation
- Branch/commit/PR created in GitHub
- Remediation status becomes pr_created

16. Merge webhook
- Merge PR in GitHub
- GitHub webhook reaches cloud endpoint
- Remediation becomes merged

- merged_at populated

17. Verify-close loop
- Run verification scan
- Remediation becomes verified_closed
- verification_scan_id and closed_at populated

18. Drift detection
- Drift check on unchanged remediation => clean
- Drift check on changed file => drifted
- Audit event recorded

19. Drift response
- Drift auto-creates follow-up remediation
- Parent/child linkage is correct
- Acknowledge drift works
- Revalidate drift works

20. Notifications
- Generic webhook delivery works
- Validation failure emits event
- Remediation merged emits event
- Remediation drifted/follow-up emits event
- Retry queue works for failed deliveries

21. Compliance report JSON
- /org/compliance-report?format=json returns valid payload
- Summary numbers make sense
- Remediation list includes validation/merge/verify/drift fields
- Recent alerts are present

22. Dashboard UI
- Executive metrics load
- Remediations list loads
- Validation status visible
- Drift status visible
- Report JSON view works

23. Persistence / restart safety
- Restart local containers
- Cloud revision redeploy
- Data still present in Postgres
- Scans/remediations/audit/report still load

24. Security / negative tests
- Missing token rejected
- Invalid token rejected
- Wrong role denied

- Invalid GitHub credential handled cleanly
- Forbidden remediation content blocked by guardrails

25. Final end-to-end money flow
- Login
- Sync repo
- Scan
- Correlate
- Compliance fail
- Suggest
- Approve
- Validate
- Create PR
- Merge
- Verify close
- Drift check
- Follow-up remediation if drifted
- Compliance report reflects everything